

Task 1 - Reconnaissance & Vulnerability Scanning

1. Introduction

This report documents the findings and steps involved in conducting reconnaissance and vulnerability scanning on a test target, **Metasploitable 2**, which is a purposely vulnerable machine designed for penetration testing exercises. The target system was hosted in a **VM (Virtual Machine)** environment, and the attacker machine used was **Linux Mint**. Both machines were isolated within a controlled and secure network to prevent any unintended harm to external systems. No systems outside of the authorized test environment were affected during the assessment.

Tools Used in this task

- Ping
- Nmap
- Nikto

Machines Used in this task

- Linux Mint Attacker Machine
- Metasploitable 2 safe environment Victim Machine

The primary goal of this assessment is to:

- Perform a **Reconnaissance** of the target system to identify open ports and active services using **Nmap** .
- Execute **Vulnerability Scanning** on the identified services using both **Nmap** and **Nikto**.
- Document the findings, including identified vulnerabilities, to outline potential security risks.

This report includes an in-depth analysis of the steps taken, commands used, and the vulnerabilities discovered during the assessment.

2.Methodology

2.1 Pre-Scan Steps: Checking Connectivity

The first step in any security assessment is to ensure the target is reachable and responsive. To verify that the **Metasploitable 2** machine was online and available for testing, a basic **Ping** test was performed.

Ping Command:

```
ping -c 8 192.168.56.101
```

Here's a breakdown of the command:

- ping** : ping is the command used to send ICMP(Internet Control Message Protocol) echo requests to a specified IP address or hostname. It helps in determining the network connectivity between our machine and the target system.
- c 8** : The **-c** flag stands for **count**. It specifies the number of **ICMP echo requests** to send to the target. In this case, it will send 8 ping requests.

Ping Result

	File: ping_test.txt
1	PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data.
2	64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=0.549 ms
3	64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.551 ms
4	64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=0.552 ms
5	64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=0.540 ms
6	64 bytes from 192.168.56.101: icmp_seq=5 ttl=64 time=0.559 ms
7	64 bytes from 192.168.56.101: icmp_seq=6 ttl=64 time=0.598 ms
8	64 bytes from 192.168.56.101: icmp_seq=7 ttl=64 time=0.529 ms
9	64 bytes from 192.168.56.101: icmp_seq=8 ttl=64 time=0.361 ms
10	
11	--- 192.168.56.101 ping statistics ---
12	8 packets transmitted, 8 received, 0% packet loss, time 7190ms
13	rtt min/avg/max/mdev = 0.361/0.529/0.598/0.066 ms

The above command sends a series of ICMP echo requests to the target system at 192.168.56.101 (Metasploitable 2). The response indicated that the system was up and reachable, allowing us to proceed with further scanning.

2.2 Performing a Basic Ping Scan with Nmap

Once the target's availability is confirmed, the next step is to perform a **basic Nmap Ping Scan**. This verifies the target’s reachability using TCP probes and helps determine if any specific ports on the system are open.

Nmap Ping, OS, Service & Port Detection Scan Command:

```
nmap -PA -p 0-65535 -sV -O 192.168.56.101
```

Here's a breakdown of the nmap commands:

- PA : This option instructs Nmap to use **TCP ACK probes** to ping the target, which is useful for bypassing firewalls that block ICMP pings.
- p 0-65535 : This specifies that all ports (from 0 to 65535) should be scanned for open services.
- sV : This option enables **Service Version Detection**, allowing Nmap to identify the versions of the services running on open ports.
- O : Enables **Operating System Detection**, providing insight into the underlying OS of the target.

Nmap Result

```
File: port_service_enum.txt
1 # Nmap 7.99 scan initiated Thu Apr 23 08:13:58 2026 as: nmap -PA -p 0-65535 -sV -O -oN port_service_enum.txt 192.168.56.101
2 Nmap scan report for 192.168.56.101
3 Host is up (0.00065s latency).
4 Not shown: 65506 closed tcp ports (reset)
5 PORT      STATE SERVICE      VERSION
6 21/tcp    open  ftp          vsftpd 2.3.4
7 22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
8 23/tcp    open  telnet       Linux telnetd
9 25/tcp    open  smtp         Postfix smtpd
10 53/tcp    open  domain       ISC BIND 9.4.2
11 80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
12 111/tcp   open  rpcbind      2 (RPC #100000)
13 139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
14 445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
15 512/tcp   open  exec         netkit-rsh rexecd
16 513/tcp   open  login        OpenBSD or Solaris rlogind
17 514/tcp   open  shell        Netkit rshd
18 1099/tcp  open  java-rmi     GNU Classpath grmiregistry
19 1524/tcp  open  bindshell    Metasploitable root shell
20 2049/tcp  open  nfs          2-4 (RPC #100003)
21 2121/tcp  open  ftp          ProFTPD 1.3.1
22 3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
23 3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
24 5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
25 5900/tcp  open  vnc          VNC (protocol 3.3)
26 6000/tcp  open  X11          (access denied)
27 6667/tcp  open  irc          UnrealIRCd
28 6697/tcp  open  irc          UnrealIRCd (Admin email admin@Metasploitable.LAN)
29 8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
30 8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
31 8787/tcp  open  drb          Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
32 34262/tcp open  nlockmgr     1-4 (RPC #100021)
33 34991/tcp open  status       1 (RPC #100024)
34 35275/tcp open  java-rmi     GNU Classpath grmiregistry
35 56025/tcp open  mountd       1-3 (RPC #100005)
36 MAC Address: 08:00:27:BA:8D:B6 (Oracle VirtualBox virtual NIC)
37 Device type: general purpose
38 Running: Linux 2.6.X
39 OS CPE: cpe:/o:linux:linux_kernel:2.6
40 OS details: Linux 2.6.9 - 2.6.33
41 Network Distance: 1 hop
42 Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
43
44 OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
45 # Nmap done at Thu Apr 23 08:16:06 2026 -- 1 IP address (1 host up) scanned in 128.16 seconds
```

The above scan was important for not only confirming the target's status but also for discovering the services, open ports, OS detection and versions running on the target system, setting the stage for the vulnerability scans.

After confirming that the target was online and reachable, the Nmap results provided insight into the open ports and services running on **Metasploitable 2**. The following ports and services were identified during this step:

- Port 21 (FTP)** – Vulnerable to the **vsftpd 2.3.4 backdoor**.
- Port 22 (SSH)** – Secure Shell protocol used for remote access.
- Port 25 (SMTP)** – Simple Mail Transfer Protocol service.
- Port 80 (HTTP)** – Web server service, exposing web-based applications.
- Port 139 and 445 (SMB)** – Used for file sharing services, vulnerable to **SMB vulnerabilities**.

These open ports, along with the services detected, provided a roadmap for the next phase of scanning, where each service would be analyzed for potential vulnerabilities.

2.3 Vulnerability Scanning with Nmap

With the open ports and services identified, i proceeded to run vulnerability checks using **Nmap's** built-in **Scripting Engine (NSE)**. The `--script=vuln` option scans for known vulnerabilities associated with the services running on the target.

Some of the critical vulnerabilities identified during this phase include:

- vsftpd 2.3.4 backdoor vulnerability:**
 - This vulnerability allows unauthorized access to the system via a backdoor in **vsftpd**. Attackers can exploit this flaw to gain root access.
- POODLE (SSL Vulnerability):**
 - The scan identified vulnerabilities in the SSL/TLS configurations, specifically the **POODLE attack** (CVE-2014-3566). This flaw allows an attacker to downgrade the encryption and decrypt traffic.
- Weak Diffie-Hellman Key Exchange:**

- The target system was found to use weak Diffie-Hellman parameters, making it susceptible to passive eavesdropping and man-in-the-middle attacks.

Each of these vulnerabilities represents a significant risk to the confidentiality and integrity of the data transmitted on the system.

Nmap Vulnerability Detection Result

```
File: nmap_vuln_scan.txt

1 # Nmap 7.99 scan initiated Thu Apr 23 08:31:46 2026 as: nmap -PA -p 0-65535 -sv -O --script=vuln -oN vuln_scan.txt 192.168.56.101
2 Nmap scan report for 192.168.56.101
3 Host is up (0.00050s latency).
4 Not shown: 65506 closed tcp ports (reset)
5 PORT      STATE SERVICE      VERSION
6 21/tcp    open  ftp          vsftpd 2.3.4
7 | ftp-vsftpd-backdoor:
8 |   VULNERABLE:
9 |     vsFTPD version 2.3.4 backdoor
10 |       State: VULNERABLE (Exploitable)
11 |       IDs:  CVE:CVE-2011-2523  BID:48539
12 |       vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
13 |       Disclosure date: 2011-07-03
14 |       Exploit results:
15 |         Shell command: id
16 |         Results: uid=0(root) gid=0(root)
17 |       References:
18 |         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
19 |         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
20 |         https://www.securityfocus.com/bid/48539
21 |         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
22 |_
23 22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
24 23/tcp    open  telnet       Linux telnetd
25 25/tcp    open  smtp         Postfix smtpd
26 |_
27 | smtp-vuln-cve2010-4344:
28 |_ The SMTP server is not Exim: NOT VULNERABLE
29 |
30 | ssl-poodle:
31 |   VULNERABLE:
32 |     SSL POODLE information leak
33 |       State: VULNERABLE
34 |       IDs:  CVE:CVE-2014-3566  BID:70574
35 |       The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
36 |       products, uses nondeterministic CBC padding, which makes it easier
37 |       for man-in-the-middle attackers to obtain cleartext data via a
38 |       padding-oracle attack, aka the "POODLE" issue.
39 |       Disclosure date: 2014-10-14
40 |       Check results:
41 |         TLS_RSA_WITH_AES_128_CBC_SHA
42 |       References:
43 |         https://www.openssl.org/~bodo/ssl-poodle.pdf
44 |         https://www.imperialviolet.org/2014/10/14/poodle.html
45 |         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
46 |         https://www.securityfocus.com/bid/70574
47 |_
48 |_ sslv2-drown: ERROR: Script execution failed (use -d to debug)
49 |
50 | ssl-dh-params:
51 |   VULNERABLE:
52 |     Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
53 |       State: VULNERABLE
54 |       Transport Layer Security (TLS) services that use anonymous
55 |       Diffie-Hellman key exchange only provide protection against passive
56 |       eavesdropping, and are vulnerable to active man-in-the-middle attacks
57 |       which could completely compromise the confidentiality and integrity
58 |       of any data exchanged over the resulting session.
59 |       Check results:
60 |         ANONYMOUS DH GROUP 1
61 |         Cipher Suite: TLS_DH_anon_WITH_3DES_EDE_CBC_SHA
62 |         Modulus Type: Safe prime
63 |         Modulus Source: postfix builtin
64 |         Modulus Length: 1024
65 |         Generator Length: 8
66 |         Public Key Length: 1024
67 |       References:
68 |         https://www.ietf.org/rfc/rfc2246.txt
69 |_
70 |
71 | Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)
72 |   State: VULNERABLE
73 |   IDs:  CVE:CVE-2015-4000  BID:74733
74 |   The Transport Layer Security (TLS) protocol contains a flaw that is
75 |   triggered when handling Diffie-Hellman key exchanges defined with
76 |   the DHE_EXPORT cipher. This may allow a man-in-the-middle attacker
77 |   to downgrade the security of a TLS session to 512-bit export-grade
78 |   cryptography, which is significantly weaker, allowing the attacker
79 |   to more easily break the encryption and monitor or tamper with
80 |   the encrypted stream.
81 |   Disclosure date: 2015-5-19
82 |   Check results:
```

```
76 | Check results:
77 | EXPORT-GRADE DH GROUP 1
78 | Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
79 | Modulus Type: Safe prime
80 | Modulus Source: Unknown/Custom-generated
81 | Modulus Length: 512
82 | Generator Length: 8
83 | Public Key Length: 512
84 | References:
85 | https://www.securityfocus.com/bid/74733
86 | https://weakdh.org
87 | https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-4000
88 |
89 | Diffie-Hellman Key Exchange Insufficient Group Strength
90 | State: VULNERABLE
91 | Transport Layer Security (TLS) services that use Diffie-Hellman groups
92 | of insufficient strength, especially those using one of a few commonly
93 | shared groups, may be susceptible to passive eavesdropping attacks.
94 | Check results:
95 | WEAK DH GROUP 1
96 | Cipher Suite: TLS_DHE_RSA_WITH_AES_256_CBC_SHA
97 | Modulus Type: Safe prime
98 | Modulus Source: postfix builtin
99 | Modulus Length: 1024
100 | Generator Length: 8
101 | Public Key Length: 1024
102 | References:
103 | https://weakdh.org
104 | 53/tcp open domain ISC BIND 9.4.2
105 | 80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
106 | |_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
107 | |_http-csrf:
108 | Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.56.101
109 | Found the following possible CSRF vulnerabilities:
110 |
111 | Path: http://192.168.56.101:80/dvwa/
112 | Form id:
113 | Form action: login.php
114 |
115 | Path: http://192.168.56.101:80/twiki/TwikiDocumentation.html
116 | Form id:
117 | Form action: http://Twiki.org/cgi-bin/passwd/Twiki/WebHome
118 |
119 | Path: http://192.168.56.101:80/twiki/TwikiDocumentation.html
120 | Form id:
121 | Form action: http://Twiki.org/cgi-bin/passwd/Main/WebHome
122 |
123 | Path: http://192.168.56.101:80/twiki/TwikiDocumentation.html
124 | Form id:
125 | Form action: http://Twiki.org/cgi-bin/edit/Twiki/
126 |
127 | Path: http://192.168.56.101:80/twiki/TwikiDocumentation.html
128 | Form id:
129 | Form action: http://Twiki.org/cgi-bin/view/Twiki/TwikiSkins
130 |
131 | Path: http://192.168.56.101:80/twiki/TwikiDocumentation.html
132 | Form id:
133 | Form action: http://Twiki.org/cgi-bin/manage/Twiki/ManagingWebs
134 |
135 | Path: http://192.168.56.101:80/mutillidae/index.php?page=login.php
136 | Form id: idloginform
137 | Form action: index.php?page=login.php
138 | |_http-dombased-xss: Couldn't find any DOM based XSS.
139 | |_http-fileupload-exploiter:
140 |
141 | Couldn't find a file-type field.
142 | |_http-trace: TRACE is enabled
143 | |_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
144 | |_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
145 | |_http-sql-injection: ERROR: Script execution failed (use -d to debug)
146 | |_http-slowloris-check:
147 | VULNERABLE:
148 | Slowloris DOS attack
149 | State: LIKELY VULNERABLE
150 | IDs: CVE:CVE-2007-6750
151 | Slowloris tries to keep many connections to the target web server open and hold
152 | them open as long as possible. It accomplishes this by opening connections to
153 | the target web server and sending a partial request. By doing so, it starves
154 | the http server's resources causing Denial Of Service.
```

```
155 |
156 | Disclosure date: 2009-09-17
157 | References:
158 | https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
159 | http://ha.ckers.org/slowloris/
160 | http-enum:
161 | /tikiviki/: Tikiwiki
162 | /test/: Test page
163 | /phpinfo.php: Possible information file
164 | /phpMyAdmin/: phpMyAdmin
165 | /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
166 | /icons/: Potentially interesting folder w/ directory listing
167 | /index/: Potentially interesting folder
168 | 111/tcp open rpcbind 2 (RPC #100000)
169 | rpcinfo:
170 | program version port/proto service
171 | 100000 2 111/tcp rpcbind
172 | 100000 2 111/udp rpcbind
173 | 100003 2,3,4 2049/tcp nfs
174 | 100003 2,3,4 2049/udp nfs
175 | 100005 1,2,3 43206/udp mountd
176 | 100005 1,2,3 56025/tcp mountd
177 | 100021 1,3,4 34262/tcp nlockmgr
178 | 100021 1,3,4 49526/udp nlockmgr
179 | 100024 1 34991/tcp status
180 | 100024 1 49456/udp status
181 | 139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
182 | 445/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
183 | 512/tcp open exec netkit-rsh rexecd
184 | 513/tcp open login OpenBSD or Solaris rlogind
185 | 514/tcp open shell Netkit rshd
186 | 1099/tcp open java-rmi GNU Classpath grmiregistry
187 | rmi-vuln-classloader:
188 | VULNERABLE:
189 | RMI registry default configuration remote code execution vulnerability
190 | State: VULNERABLE
191 | Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution.
192 |
193 | References:
194 | https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb
195 | 1524/tcp open bindshell Metasploitable root shell
196 | 2049/tcp open nfs 2-4 (RPC #100003)
197 | 2121/tcp open ftp ProFTPD 1.3.1
198 | 3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
199 | _ssl-ccs-injection: No reply from server (TIMEOUT)
200 | 3632/tcp open distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
201 | distcc-cve2004-2687:
202 | VULNERABLE:
203 | distcc Daemon Command Execution
204 | State: VULNERABLE (Exploitable)
205 | IDs: CVE:CVE-2004-2687
206 | Risk factor: High CVSSv2: 9.3 (HIGH) (AV:N/AC:M/Au:N/C:C/I:C/A:C)
207 | Allows executing of arbitrary commands on systems running distccd 3.1 and
208 | earlier. The vulnerability is the consequence of weak service configuration.
209 |
210 | Disclosure date: 2002-02-01
211 | Extra information:
212 |
213 | uid=1(daemon) gid=1(daemon) groups=1(daemon)
214 |
215 | References:
216 | https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-2687
217 | https://distcc.github.io/security.html
218 | https://nvd.nist.gov/vuln/detail/CVE-2004-2687
219 | 5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
220 | ssl-ccs-injection:
221 | VULNERABLE:
222 | SSL/TLS MITM vulnerability (CCS Injection)
223 | State: VULNERABLE
224 | Risk factor: High
225 | OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
226 | does not properly restrict processing of ChangeCipherSpec messages,
227 | which allows man-in-the-middle attackers to trigger use of a zero
228 | length master key in certain OpenSSL-to-OpenSSL communications, and
229 | consequently hijack sessions or obtain sensitive information, via
230 | a crafted TLS handshake, aka the "CCS Injection" vulnerability.
231 |
232 | References:
233 | http://www.openssl.org/news/secadv_20140605.txt
```



```
233 | http://www.openssl.org/news/secadv_20140605.txt
234 | https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
235 | http://www.cvedetails.com/cve/2014-0224
236 | ssl-dh-params:
237 | VULNERABLE:
238 | Diffie-Hellman Key Exchange Insufficient Group Strength
239 | State: VULNERABLE
240 | Transport Layer Security (TLS) services that use Diffie-Hellman groups
241 | of insufficient strength, especially those using one of a few commonly
242 | shared groups, may be susceptible to passive eavesdropping attacks.
243 | Check results:
244 | WEAK DH GROUP 1
245 | Cipher Suite: TLS_DHE_RSA_WITH_AES_256_CBC_SHA
246 | Modulus Type: Safe prime
247 | Modulus Source: Unknown/Custom-generated
248 | Modulus Length: 1024
249 | Generator Length: 8
250 | Public Key Length: 1024
251 | References:
252 | https://weakdh.org
253 | ssl-poodle:
254 | VULNERABLE:
255 | SSL POODLE information leak
256 | State: VULNERABLE
257 | IDs: CVE:CVE-2014-3566 BID:70574
258 | The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
259 | products, uses nondeterministic CBC padding, which makes it easier
260 | for man-in-the-middle attackers to obtain cleartext data via a
261 | padding-oracle attack, aka the "POODLE" issue.
262 | Disclosure date: 2014-10-14
263 | Check results:
264 | TLS_RSA_WITH_AES_128_CBC_SHA
265 | References:
266 | https://www.openssl.org/~bodo/ssl-poodle.pdf
267 | https://www.imperialviolet.org/2014/10/14/poodle.html
268 | https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
269 | https://www.securityfocus.com/bid/70574
270 | 5900/tcp open vnc VNC (protocol 3.3)
271 | 6000/tcp open X11 (access denied)
272 | 6667/tcp open irc UnrealIRCd
273 | irc-botnet-channels:
274 | _ ERROR: Closing Link: [192.168.56.1] (Too many unknown connections from your IP)
275 | 6697/tcp open irc UnrealIRCd
276 | _ssl-ccs-injection: No reply from server (TIMEOUT)
277 | irc-botnet-channels:
278 | _ ERROR: Closing Link: [192.168.56.1] (Too many unknown connections from your IP)
279 | 8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
280 | 8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
281 | _http-dombased-xss: Couldn't find any DOM based XSS.
282 | http-csrf:
283 | Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.56.101
284 | Found the following possible CSRF vulnerabilities:
285 |
286 | Path: http://192.168.56.101:8180/admin/
287 | Form id: username
288 | Form action: j_security_check;jsessionId=AA2911238E9ECB14387E6185526DEB6A
289 |
290 | Path: http://192.168.56.101:8180/servlets-examples/servlet/CookieExample
291 | Form id:
292 | Form action: CookieExample
293 |
294 | Path: http://192.168.56.101:8180/servlets-examples/servlet/SessionExample
295 | Form id:
296 | Form action: SessionExample;jsessionId=EA1E727EA3D41B73D709A75274815255
297 |
298 | Path: http://192.168.56.101:8180/servlets-examples/servlet/SessionExample
299 | Form id:
300 | Form action: SessionExample;jsessionId=EA1E727EA3D41B73D709A75274815255
301 |
302 | Path: http://192.168.56.101:8180/servlets-examples/servlet/RequestParamExample
303 | Form id:
304 | Form action: RequestParamExample
305 | _http-stored-xss: Couldn't find any stored XSS vulnerabilities.
306 | _http-sql-injection: ERROR: Script execution failed (use -d to debug)
307 | http-enum:
308 | /admin/: Possible admin folder
309 | /admin/index.html: Possible admin folder
310 | /admin/login.html: Possible admin folder
311 | /admin/admin.html: Possible admin folder
```

```

312 | /admin/account.html: Possible admin folder
313 | /admin/admin_login.html: Possible admin folder
314 | /admin/home.html: Possible admin folder
315 | /admin/admin-login.html: Possible admin folder
316 | /admin/adminLogin.html: Possible admin folder
317 | /admin/controlpanel.html: Possible admin folder
318 | /admin/cp.html: Possible admin folder
319 | /admin/index.jsp: Possible admin folder
320 | /admin/login.jsp: Possible admin folder
321 | /admin/admin.jsp: Possible admin folder
322 | /admin/home.jsp: Possible admin folder
323 | /admin/controlpanel.jsp: Possible admin folder
324 | /admin/admin-login.jsp: Possible admin folder
325 | /admin/cp.jsp: Possible admin folder
326 | /admin/account.jsp: Possible admin folder
327 | /admin/admin_login.jsp: Possible admin folder
328 | /admin/adminLogin.jsp: Possible admin folder
329 | /manager/html/upload: Apache Tomcat (401 Unauthorized)
330 | /manager/html: Apache Tomcat (401 Unauthorized)
331 | /admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html: OpenCart/FCKeditor File upload
332 | /admin/includes/FCKeditor/editor/filemanager/upload/test.html: ASP Simple Blog / FCKeditor File Upload
333 | /admin/jscript/upload.html: Lizard Cart/Remote File upload
334 | /webdav/: Potentially interesting folder
335 | http-cookie-flags:
336 |   /admin/:
337 |     JSESSIONID:
338 |       httponly flag not set
339 |   /admin/index.html:
340 |     JSESSIONID:
341 |       httponly flag not set
342 |   /admin/login.html:
343 |     JSESSIONID:
344 |       httponly flag not set
345 |   /admin/admin.html:
346 |     JSESSIONID:
347 |       httponly flag not set
348 |   /admin/account.html:
349 |     JSESSIONID:
350 |       httponly flag not set
351 |   /admin/admin_login.html:
352 |     JSESSIONID:
353 |       httponly flag not set
354 |   /admin/home.html:
355 |     JSESSIONID:
356 |       httponly flag not set
357 |   /admin/admin-login.html:
358 |     JSESSIONID:
359 |       httponly flag not set
360 |   /admin/adminLogin.html:
361 |     JSESSIONID:
362 |       httponly flag not set
363 |   /admin/controlpanel.html:
364 |     JSESSIONID:
365 |       httponly flag not set
366 |   /admin/cp.html:
367 |     JSESSIONID:
368 |       httponly flag not set
369 |   /admin/index.jsp:
370 |     JSESSIONID:
371 |       httponly flag not set
372 |   /admin/login.jsp:
373 |     JSESSIONID:
374 |       httponly flag not set
375 |   /admin/admin.jsp:
376 |     JSESSIONID:
377 |       httponly flag not set
378 |   /admin/home.jsp:
379 |     JSESSIONID:
380 |       httponly flag not set
381 |   /admin/controlpanel.jsp:
382 |     JSESSIONID:
383 |       httponly flag not set
384 |   /admin/admin-login.jsp:
385 |     JSESSIONID:
386 |       httponly flag not set
387 |   /admin/cp.jsp:
388 |     JSESSIONID:
389 |       httponly flag not set
390 |   /admin/account.jsp:
391 |     JSESSIONID:
392 |       httponly flag not set
393 |   /admin/admin_login.jsp:
394 |     JSESSIONID:
395 |       httponly flag not set
396 |   /admin/adminLogin.jsp:
397 |     JSESSIONID:
398 |       httponly flag not set
399 |   /admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html:
400 |     JSESSIONID:
401 |       httponly flag not set
402 |   /admin/includes/FCKeditor/editor/filemanager/upload/test.html:
403 |     JSESSIONID:
404 |       httponly flag not set
405 |   /admin/jscript/upload.html:
406 |     JSESSIONID:
407 |       httponly flag not set
408 | _http-server-header: Apache-Coyote/1.1
409 | 8787/tcp open drb Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)
410 | 34262/tcp open nlockmgr 1-4 (RPC #100021)
411 | 34991/tcp open status 1 (RPC #100024)
412 | 35275/tcp open java-rmi GNU Classpath gmrregistry
413 | rmi-vuln-classloader:
414 |   VULNERABLE:
415 |     RMI registry default configuration remote code execution vulnerability
416 |     State: VULNERABLE
417 |     Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution.
418 |
419 |     References:
420 |     - https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb
421 | 56025/tcp open mountd 1-3 (RPC #100005)
422 | MAC Address: 08:00:27:BA:8D:B6 (Oracle VirtualBox virtual NIC)
423 | Device type: general purpose
424 | Running: Linux 2.6.X
425 | OS CPE: cpe:/o:linux:linux_kernel:2.6
426 | OS details: Linux 2.6.9 - 2.6.33
427 | Network Distance: 1 hop
428 | Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
429 |
430 | Host script results:
431 | |_smb-vuln-ms10-054: false
432 | |_smb-vuln-regsvc-dos: ERROR: Script execution failed (use -d to debug)
433 | |_smb-vuln-ms10-061: false
434 |
435 | OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
436 | # Nmap done at Thu Apr 23 08:39:11 2026 -- 1 IP address (1 host up) scanned in 444.98 seconds

```

(END)

Each of these vulnerabilities represents a significant risk to the confidentiality and integrity of the data transmitted on the system.

2.4 Vulnerability Scanning with Nikto

After the Nmap vulnerability scan, i performed a **Nikto** web application scan to further evaluate the security of the web server running on the target machine.

Nikto Vulnerability Scan Command:

```
sudo nikto -Tuning x -evasion 12 -h 192.168.56.101
```

Breakdown of the Command:

- nikto :**
This is the main command to run the **Nikto** web scanner. Nikto is used for identifying vulnerabilities in web applications and servers.
- Tuning x :**
The `-Tuning` option is used to **tune** the scan to focus on specific vulnerability checks. It allows the user to specify which types of tests to run. The value `x` (or a specific number) can represent various tuning options. Here's a general overview of the tuning options in Nikto:
 - Tuning 1 :** Check for **SQL injection** vulnerabilities.
 - Tuning 2 :** Check for **Cross-Site Scripting (XSS)** vulnerabilities.
 - Tuning 3 :** Scan for **file inclusion** vulnerabilities.
 - Tuning 4 :** Check for **HTTP header issues** (e.g., missing security headers).
 - Tuning 5 :** Look for **directory traversal vulnerabilities**.
 - Tuning x :** In this case, `x` represents a custom tuning parameter, meaning **Nikto will check a wide range of vulnerabilities** across different categories.So, `-Tuning x` likely tells Nikto to perform a general vulnerability scan with multiple checks, possibly including SQL injection, XSS, file inclusion, and other common vulnerabilities.
- evasion 12 :**
The `-evasion` option enables **evasion techniques** to help bypass detection by web application firewalls (WAFs), intrusion detection systems (IDS), or other security measures that may block traditional scanning tools.

Nikto Vulnerability Scan Results

```
File: nikto_vuln_scan.txt
1  - Nikto v2.6.0
2
3  + Target IP:      192.168.56.101
4  + Target Hostname: 192.168.56.101
5  + Target Port:    80
6  + Using Encoding: Random URI encoding (non-UTF8)
7  + Using Encoding: Directory self-reference (/./)
8  + Platform:      Unknown
9  + Start Time:    2026-04-23 09:13:33 (GMT2)
10
11 + Server: Apache/2.2.8 (Ubuntu) DAV/2
12 + No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
13 + [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
14 + [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
15 + [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
16 + [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
17 + [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
18 + [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
19 + [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
20 + [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
21 + [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
22 + [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
23 + 651 requests: 0 errors and 10 items reported on the remote host
24 + End Time:      2026-04-23 09:13:34 (GMT2) (1 seconds)
25
26 + 1 host(s) tested
```

Nikto scans for common web vulnerabilities, such as **Cross-Site Scripting (XSS)**, **SQL Injection** flaws, and missing security headers. The results from the Nikto scan revealed the following findings:

- Missing HTTP security headers:**
 - The target web server was not configured with critical security headers like **Strict-Transport-Security**, **X-Content-Type-Options**, and **X-Frame-Options**. These headers help protect against attacks such as clickjacking and cross-site scripting.
- Outdated Software:**
 - Nikto identified outdated software versions running on the web server, which are susceptible to well-known vulnerabilities.
- Potential for XSS Attacks:**
 - Multiple pages on the target web application were vulnerable to **Cross-Site Scripting (XSS)**, a type of vulnerability that allows attackers to inject malicious scripts into the web pages viewed by other users.

3. Findings and Vulnerabilities

The reconnaissance and vulnerability scans revealed several critical security issues on **Metasploitable 2**. The most important findings are as follows:

- vsftpd 2.3.4 backdoor** vulnerability, which allows unauthorized access.
- SSL/TLS vulnerabilities** (including POODLE and weak key exchange parameters) that can expose encrypted traffic to attackers.
- Cross-Site Scripting (XSS)** vulnerabilities in web applications.
- Missing HTTP security headers**, making the target susceptible to various attacks.

These vulnerabilities should be mitigated by applying patches, enhancing configuration security, and removing or securing vulnerable services.

4. Conclusion

The security assessment of **Metasploitable 2** revealed multiple critical vulnerabilities that could be exploited by attackers. These vulnerabilities could lead to unauthorized access, data interception, and other types of attacks.

The results of this scan highlight the importance of securing both the system's services and the web applications running on it. Immediate remediation steps include:

- Upgrading or patching vulnerable services (e.g., vsftpd).
- Implementing proper SSL/TLS configurations to prevent attacks like POODLE.
- Addressing web application vulnerabilities, such as XSS, by sanitizing user input and securing HTTP headers.

This assessment was conducted in a controlled environment with no harm to external systems. It provides a valuable learning experience for understanding common vulnerabilities and the steps necessary to secure a system.

Thank You